Strong authentication and privileged access — Keycloak

Crédit Océane (fictif) · Keycloak — royaume oceane (fournisseur d'identité)

Prepared by: **Attest (AI-assisted)**
Date: **2026-11-11 12:27**

Auditor sign-off: **pending**
Run: **20261111-121909-keycloak-bench-meta**

Owner: **IT department — IAM team**

1. Executive summary

OPINION AT TESTING

Qualified opinion

Basis for opinion

7 controls tested (6 conclusive) against: DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4. Tests run on 2026-11-11 12:27, environment: Test Keycloak (fictitious realm). The opinion rests solely on the verdicts of the deterministic test scripts and on the evidence sealed in the audit trail. Opinion qualified: 1 control(s) inconclusive or under review (test and evidence disagree) do not count as compliant.

Scope limitation: Work programme and test scripts drafted by AI and not yet reviewed by an auditor; requirements needing document review or interview are not covered; the opinion applies at the test date only.

7 controls tested	**0** findings	**0** findings closed and verified	**0** open findings
0 human approvals	**116** sensitive data items masked in evidence	**2 min 31 s** audit duration	**$0.132 *** measured AI cost

Key messages

- No findings: every tested control is compliant.
- 1 control needs review: the test and the visual evidence disagree.

2. Scope and method

Engagement	AUD-2026-KC-01
Entity	Crédit Océane (fictif)
System	Keycloak — royaume oceane (fournisseur d'identité)
System criticality	Supports critical or important functions (DORA)
Environment	Test Keycloak (fictitious realm)
Owner	IT department — IAM team
Lead auditor	Attest CI (automated run, no human auditor)
Date	2026-11-11 12:27
Framework	DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4
Audited target	Keycloak (open-source identity provider), through the read-only gateway

In scope

- Security settings of the Keycloak realm (password, lockout, session, logging)
- Realm accounts and members of the admin role

Out of scope

- Intrinsic strength of MFA factors and custom authentication flows
- Clients, identity federation and connected applications
- Hosting and operation of the Keycloak server

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. No remediation was applied during this engagement: each finding is handed to the system owner for an action plan, and closing it will require a new test once the gap has been addressed.
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- Point-in-time test: the configuration was observed on 2026-11-11; the tests assess the design and implementation of the controls at that date, not their operating effectiveness over a period.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	STATUS	DUE DATE
–	PSI-4.1	MFA enforced for privileged administrator accounts	Critical	Compliant		
–	PSI-4.2	MFA enforced for users of critical system	High	Compliant		
–	PSI-4.3	Minimum password length and complexity	Medium	Compliant		
–	PSI-4.4	Account lockout after repeated failures	Medium	Compliant		
–	PSI-4.5	Inactive session timeout	Medium	Compliant		
–	PSI-4.6	Logging of administration actions	High	Compliant		
–	PSI-4.7	No generic or shared administrator accounts	High	Needs review		

4. Detailed findings and controls

PSI-4.1 MFA enforced for privileged administrator accounts

Critical · Compliant

Compliant control — Every account holding the realm role admin must have multi-factor authentication configured. · DORA 9(4)(d), RTS 21(1)(f)(ii)
Observed: `[true, true, true, true, true, true, true, true]`



At testing — The screenshot corroborates the test. All eight listed admin accounts show MFA (OTP configured) as yes. · 8/8 sensitive data items masked (7 spotted by the AI, the rest by the deterministic safety net)
`2026-11-11 12:28:15 · SHA-256 82a1d5916646424f…`

PSI-4.2 MFA enforced for users of critical system

High · Compliant

Compliant control — Every user account in the Keycloak realm, which supports critical or important functions, must have multi-factor authentication configured. · DORA 9(4)(d), RTS 21(1)(f)(ii)
Observed: `[]`

Keycloak · oceane read-only audit view

User accounts

Accounts 1–100 · 100 per page next page →

USERNAME	E-MAIL	REALM ROLE	ENABLED	MFA (OTP CONFIGURED)
a.allain	[redacted]	—	yes	**yes**
a.daniel	[redacted]	—	yes	**yes**
a.dubois	[redacted]	—	yes	**yes**
a.girard	[redacted]	—	yes	**yes**
a.guillou	[redacted]	—	yes	**yes**
a.henaff	[redacted]	—	yes	**yes**
a.jegou	[redacted]	—	yes	**yes**
a.kerbrat	[redacted]	admin	yes	**yes**
a.kerbrat2	[redacted]	—	yes	**yes**
a.le-bihan	[redacted]	—	yes	**yes**
a.le-gall	[redacted]	—	yes	**yes**
a.martin	[redacted]	—	yes	**yes**
a.pennec	[redacted]	—	yes	**yes**
a.raoul	[redacted]	—	yes	**yes**
a.richard	[redacted]	—	yes	**yes**
b.gourmelen	[redacted]	—	yes	**yes**
b.le-corre	[redacted]	—	yes	**yes**
b.martin	[redacted]	—	yes	**yes**
b.olier	[redacted]	—	yes	**yes**
b.richard	[redacted]	—	yes	**yes**
b.robert	[redacted]	—	yes	**yes**
b.uguen	[redacted]	—	yes	**yes**
c.bonnet	[redacted]	—	yes	**yes**
c.briand	[redacted]	—	yes	**yes**
c.cloarec	[redacted]	—	yes	**yes**
c.derrien	[redacted]	—	yes	**yes**
c.dupont	[redacted]	—	yes	**yes**
c.fournier	[redacted]	—	yes	**yes**
c.garcia	[redacted]	—	yes	**yes**
c.girard	[redacted]	—	yes	**yes**
c.hamon	[redacted]	—	yes	**yes**
c.hamon2	[redacted]	—	yes	**yes**
c.itier	[redacted]	admin	yes	**yes**
c.kerbrat	[redacted]	—	yes	**yes**
c.kerjean	[redacted]	—	yes	**yes**
c.kervella	[redacted]	—	yes	**yes**
c.kervella2	[redacted]	—	yes	**yes**
c.lagadec	[redacted]	—	yes	**yes**
c.lagadec2	[redacted]	—	yes	**yes**
c.lambert	[redacted]	—	yes	**yes**
c.le-goff	[redacted]	—	yes	**yes**
c.le-meur	[redacted]	—	yes	**yes**
c.pennec	[redacted]	—	yes	**yes**
c.roux	[redacted]	—	yes	**yes**
c.thepaut	[redacted]	—	yes	**yes**
c.uguen	[redacted]	—	yes	**yes**
d.dubois	[redacted]	—	yes	**yes**
d.lambert	[redacted]	—	yes	**yes**
d.le-corre	[redacted]	—	yes	**yes**

d.le-corre	—	yes	**yes**
d.raoul	—	yes	**yes**
d.uguen	—	yes	**yes**
d.vincent	—	yes	**yes**
e.floch	—	yes	**yes**
e.lagadec	—	yes	**yes**
e.le-gall	—	yes	**yes**
e.quillien	—	yes	**yes**
e.riou	—	yes	**yes**
e.tanguy	—	yes	**yes**
f.bernard	—	yes	**yes**
f.jegou	—	yes	**yes**
g.bonnet	—	yes	**yes**
g.briand	—	yes	**yes**
g.girard	—	yes	**yes**
g.laurent	—	yes	**yes**
g.le-corre	—	yes	**yes**
g.le-gall	—	yes	**yes**
g.le-goff	—	yes	**yes**
g.le-goff2	—	yes	**yes**
g.martin	—	yes	**yes**
g.martin2	—	yes	**yes**
g.michel	—	yes	**yes**
g.morvan	—	yes	**yes**
g.uguen	—	yes	**yes**
h.guillou	—	yes	**yes**
h.laurent	—	yes	**yes**
h.mercier	—	yes	**yes**
h.mercier2	—	yes	**yes**
h.petit	—	yes	**yes**
h.prigent	—	yes	**yes**
h.richard	—	yes	**yes**
h.salaun	—	yes	**yes**
h.thepaut	—	yes	**yes**
helpdesk	—	yes	**yes**
i.bertrand	—	yes	**yes**
i.david	—	yes	**yes**
i.hamon	—	yes	**yes**
i.jacq	—	yes	**yes**
i.jaouen	—	yes	**yes**
i.le-bihan	—	yes	**yes**
i.le-meur	—	yes	**yes**
i.martin	—	yes	**yes**
i.morvan	—	yes	**yes**
i.roux	—	yes	**yes**
i.salaun	—	yes	**yes**
i.simon	—	yes	**yes**
i.uguen	—	yes	**yes**
i.yvinec	—	yes	**yes**
j.bertrand	—	yes	**yes**
j.cloarec	—	yes	**yes**
j.garcia	—	yes	**yes**

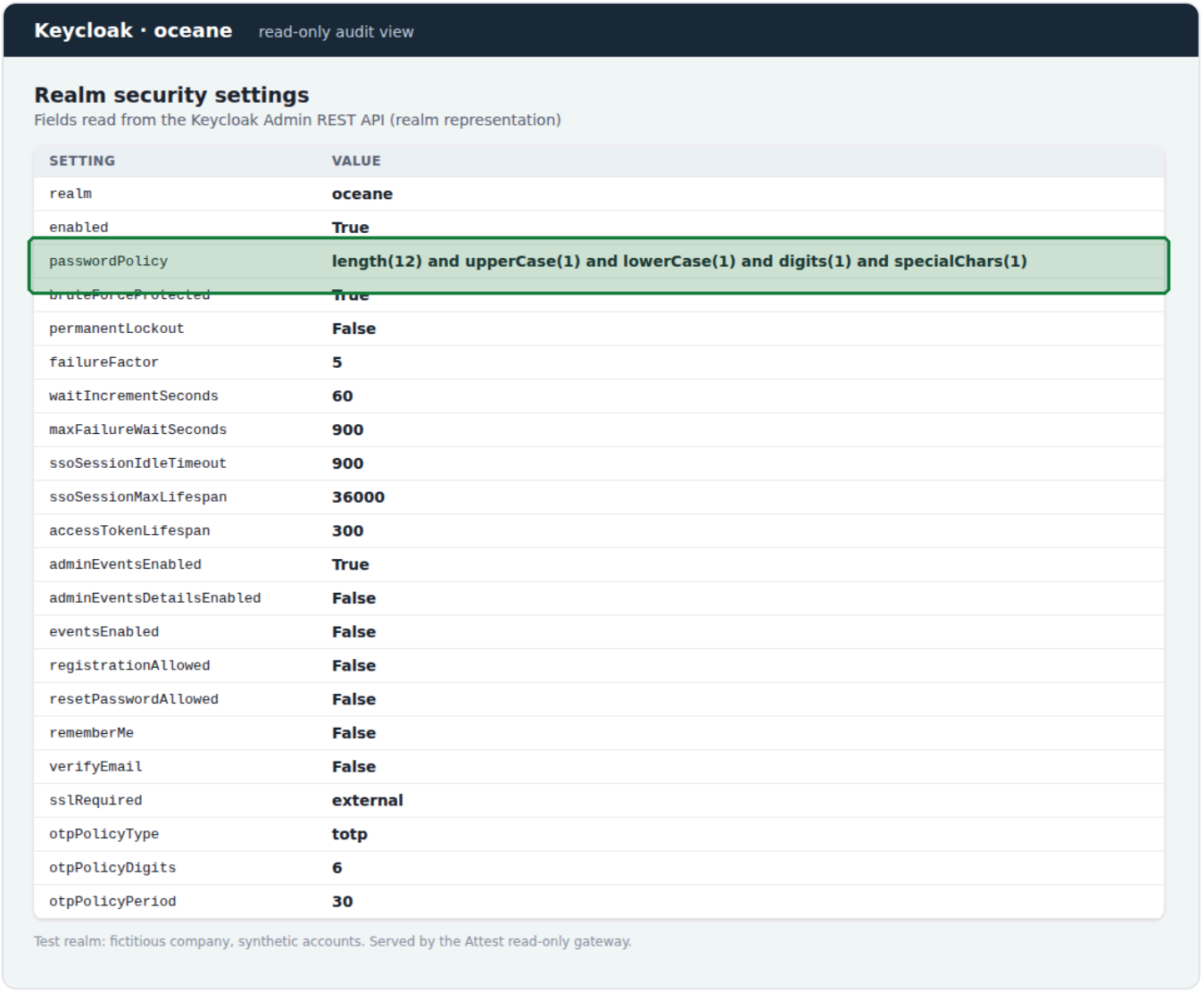
Test realm: fictitious company, [illegible] accounts [illegible] by the Attest [illegible] gateway.

At testing — The screenshot corroborates the test. All 100 visible user rows from a.allain to j.garcia show MFA (OTP configured) as yes, consistent with the pass result. · 100/100 sensitive data items masked (98 spotted by the AI, the rest by the deterministic safety net)
`2026-11-11 12:30:19 · SHA-256 63e46bef1b3d66d3…`

PSI-4.3 Minimum password length and complexity

Medium · Compliant

Compliant control — Password policy must require at least 12 characters with complexity requirements. · DORA 9(4)(d)
Observed: `length(12) and upperCase(1) and lowerCase(1) and digits(1) and specialChars(1)`



Keycloak · oceane read-only audit view

Realm security settings

Fields read from the Keycloak Admin REST API (realm representation)

SETTING	VALUE
realm	**oceane**
enabled	**True**
passwordPolicy	**length(12) and upperCase(1) and lowerCase(1) and digits(1) and specialChars(1)**
bruteForceProtected	**True**
permanentLockout	**False**
failureFactor	**5**
waitIncrementSeconds	**60**
maxFailureWaitSeconds	**900**
ssoSessionIdleTimeout	**900**
ssoSessionMaxLifespan	**36000**
accessTokenLifespan	**300**
adminEventsEnabled	**True**
adminEventsDetailsEnabled	**False**
eventsEnabled	**False**
registrationAllowed	**False**
resetPasswordAllowed	**False**
rememberMe	**False**
verifyEmail	**False**
sslRequired	**external**
otpPolicyType	**totp**
otpPolicyDigits	**6**
otpPolicyPeriod	**30**

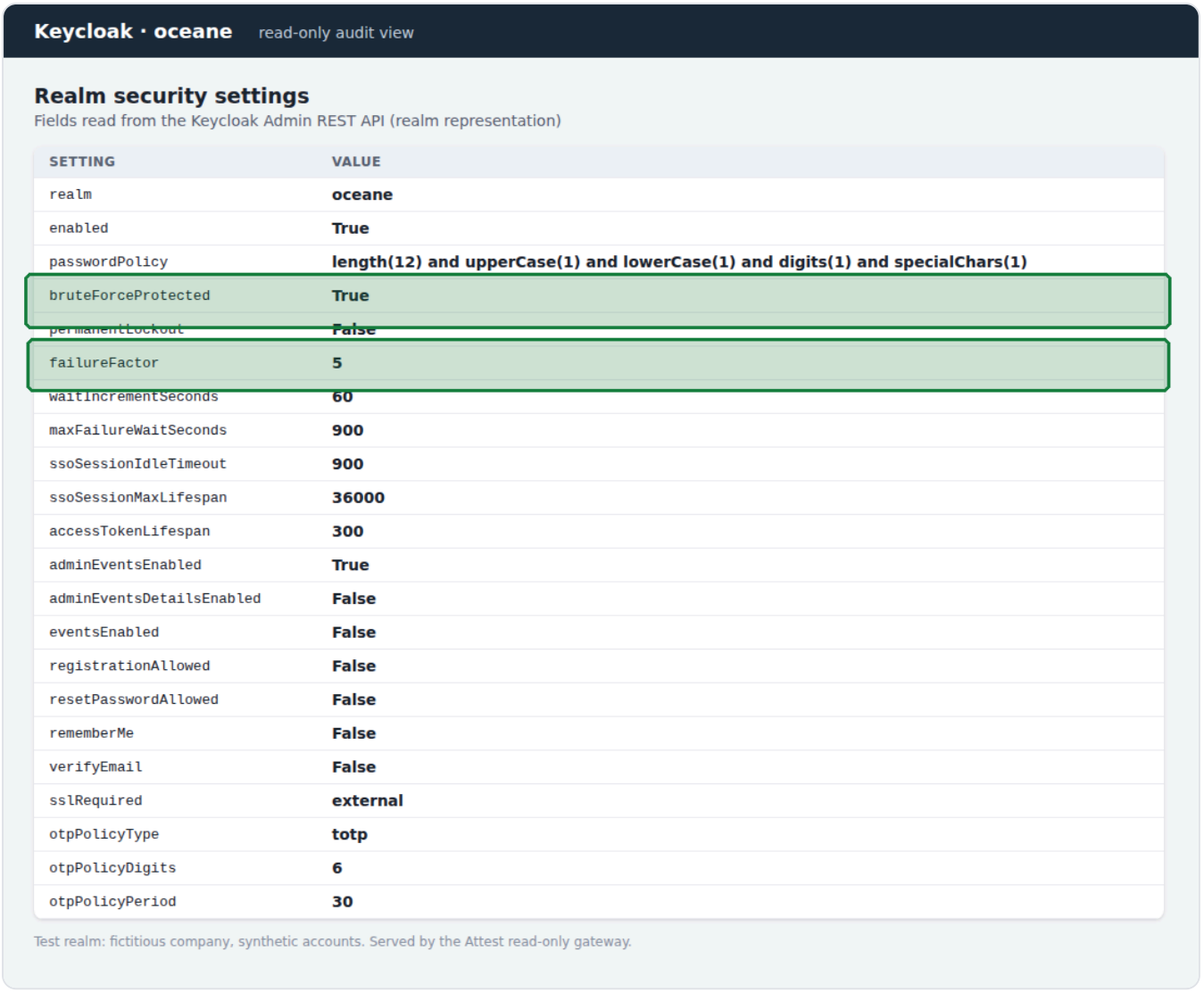
Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

At testing — The screenshot corroborates the test. The passwordPolicy row shows length 12 with upperCase, lowerCase, digits and specialChars as expected.
`2026-11-11 12:28:05 · SHA-256 49ed6b4d14bcda3e…`

PSI-4.4 Account lockout after repeated failures

Medium · Compliant

Compliant control — Account lockout must be enabled and trigger after at most 5 failed logins, never disabled. · DORA 9(4)(c)
Observed: `{"bruteForceProtected": true, "failureFactor": 5}`



At testing — The screenshot corroborates the test. Screenshot shows brute-force protection enabled with failure factor 5, matching the test result.
`2026-11-11 12:28:06 · SHA-256 4d9b5714f94845c3…`

PSI-4.5 Inactive session timeout

Medium · Compliant

Compliant control — Idle sessions must expire after at most 15 minutes and idle timeout must never be disabled. · DORA 9(4)(c)
Observed: `900`

Keycloak · oceane read-only audit view

Realm security settings

Fields read from the Keycloak Admin REST API (realm representation)

SETTING	VALUE
realm	**oceane**
enabled	**True**
passwordPolicy	**length(12) and upperCase(1) and lowerCase(1) and digits(1) and specialChars(1)**
bruteForceProtected	**True**
permanentLockout	**False**
failureFactor	**5**
waitIncrementSeconds	**60**
maxFailureWaitSeconds	**900**
ssoSessionIdleTimeout	**900**
ssoSessionMaxLifespan	**36000**
accessTokenLifespan	**300**
adminEventsEnabled	**True**
adminEventsDetailsEnabled	**False**
eventsEnabled	**False**
registrationAllowed	**False**
resetPasswordAllowed	**False**
rememberMe	**False**
verifyEmail	**False**
sslRequired	**external**
otpPolicyType	**totp**
otpPolicyDigits	**6**
otpPolicyPeriod	**30**

Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

At testing — The screenshot corroborates the test. The screenshot shows ssoSessionIdleTimeout set to 900 seconds, matching the automated test observed value.
`2026-11-11 12:28:24 · SHA-256 14ef58622faa1bc2…`

PSI-4.6 Logging of administration actions

High Compliant

Compliant control — All administration actions must be recorded as admin events. · RTS 12(2)(c)(i)
Observed: `true`

Keycloak · oceane read-only audit view

Realm security settings

Fields read from the Keycloak Admin REST API (realm representation)

SETTING	VALUE
realm	**oceane**
enabled	**True**
passwordPolicy	**length(12) and upperCase(1) and lowerCase(1) and digits(1) and specialChars(1)**
bruteForceProtected	**True**
permanentLockout	**False**
failureFactor	**5**
waitIncrementSeconds	**60**
maxFailureWaitSeconds	**900**
ssoSessionIdleTimeout	**900**
ssoSessionMaxLifespan	**36000**
accessTokenLifespan	**300**
adminEventsEnabled	**True**
adminEventsDetailsEnabled	**False**
eventsEnabled	**False**
registrationAllowed	**False**
resetPasswordAllowed	**False**
rememberMe	**False**
verifyEmail	**False**
sslRequired	**external**
otpPolicyType	**totp**
otpPolicyDigits	**6**
otpPolicyPeriod	**30**

Test realm: fictitious company, synthetic accounts. Served by the Attest read-only gateway.

At testing — The screenshot corroborates the test. Screenshot shows adminEventsEnabled as True, matching the expected value.
`2026-11-11 12:28:23 · SHA-256 e837b208bc124155…`

PSI-4.7 No generic or shared administrator accounts

High · Needs review

CRITERIA

No account holding the realm role admin may be generic or shared, each admin must have a nominative username of form initiale.nom and a personal email, not a function identifier or shared mailbox.

PSI-4.7 · DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii)

CONDITION

Observed: `["a.kerbrat"]`
Expected: `for role admin members, username matches initiale.nom pattern and email is personal, no generic username (ops, admin, root) or shared mailbox (ops-partage@, adm…`

Checked 8 admin members, 1 with generic/shared or non-nominative username or email.

PROBABLE CAUSE

Use of operational shared accounts for administration persisted due to missing joiner-mover-leaver and naming controls. (AI hypothesis, not tested: to be confirmed with the owner)

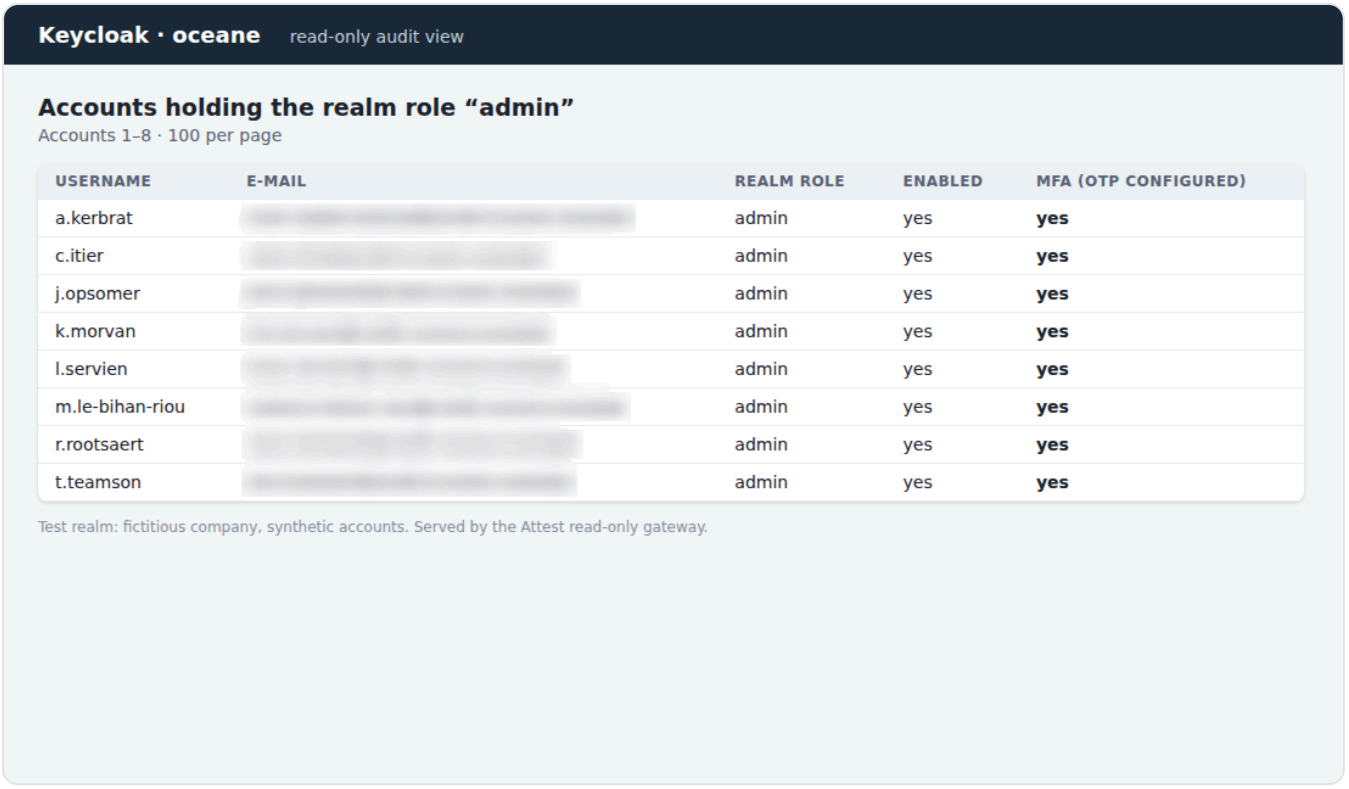
RISK

Shared administrator accounts prevent accountability and allow uncontrolled privileged access.

RECOMMENDATION

Remove admin rights from all generic or shared accounts and reissue nominative administrator accounts.

Test procedure: Retrieve all members of the realm role admin via GET /api/kc/roles/admin/users and verify username and email are nominative and not generic or shared.



At testing — The screenshot does NOT corroborate the test. All eight admin rows show initiale.nom usernames with matching personal emails and no generic or shared identifiers. · 8/8 sensitive data items masked (7 spotted by the AI, the rest by the deterministic safety net)
`2026-11-11 12:28:49 · SHA-256 921c7789c113d2c7…`

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.1	C1 · MFA enforced for privileged administrator accounts	6b0de4e7e8437e78 · script library (reused)	Compliant
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.2	C2 · MFA enforced for users of critical system	c2e61c28808cef93 · script library (reused)	Compliant
DORA 9(4)(d)	PSI-4.3	C3 · Minimum password length and complexity	d0cead329c96459f · script library (reused)	Compliant
DORA 9(4)(c)	PSI-4.4	C4 · Account lockout after repeated failures	8e6c056f9268416a · script library (reused)	Compliant
DORA 9(4)(c)	PSI-4.5	C5 · Inactive session timeout	a1dcf90b1888dffd · script library (reused)	Compliant
RTS 12(2)(c)(i)	PSI-4.6	C6 · Logging of administration actions	033e67f8092e2f55 · script library (reused)	Compliant
DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii)	PSI-4.7	C7 · No generic or shared administrator accounts	ad12cb2ee7e9bb75 · script library (reused)	Needs review

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-11 12:28:15	82a1d5916646424f8475020d187d7e9546c0fcaa692691af2bc20be931b06e8f
evidence/C2_before.png	C2 · At testing	2026-11-11 12:30:19	63e46bef1b3d66d3fef12173f38b5d8c10d66987b392af82bf9450319a9d1584
evidence/C3_before.png	C3 · At testing	2026-11-11 12:28:05	49ed6b4d14bcda3e63a50d9905595e1df21c8fc0d65520b40e8ccfac384bc66e
evidence/C4_before.png	C4 · At testing	2026-11-11 12:28:06	4d9b5714f94845c37661f86b38c85b03a88016f1b4904b463d49786d783ce08f
evidence/C5_before.png	C5 · At testing	2026-11-11 12:28:24	14ef58622faa1bc2ec9fe75747a73a3d9c271b322ca85ec22ad8d510ab8647b3
evidence/C6_before.png	C6 · At testing	2026-11-11 12:28:23	e837b208bc124155a172b5113f7d9d67dab75ffc8bdbc09268abe61737dab31d
evidence/C7_before.png	C7 · At testing	2026-11-11 12:28:49	921c7789c113d2c7275d6e829cc1c6fdc8d4d92594a8c9a792bbb45c781db857

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)
muse-spark-1.3	7	15,519	26,459	0	0.1318

sam-3.1	19	0	0	19	price not published
Total					**0.1318**

Sensitive data (personal data and secrets) in evidence: 112/116 spotted by Muse Spark + SAM, 116/116 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`5cbf14cceec8974fcc33020de34163504bb6e15ea30526f64daaf1f99855c06b`